

SoundScore V1 — Architecture Report

Author: Madhav Chauhan **Date:** 2026-03-19 **Version:** 0.1.0 **Audit Branch:** audit/deep-sweep-20260319
(8 passes completed)

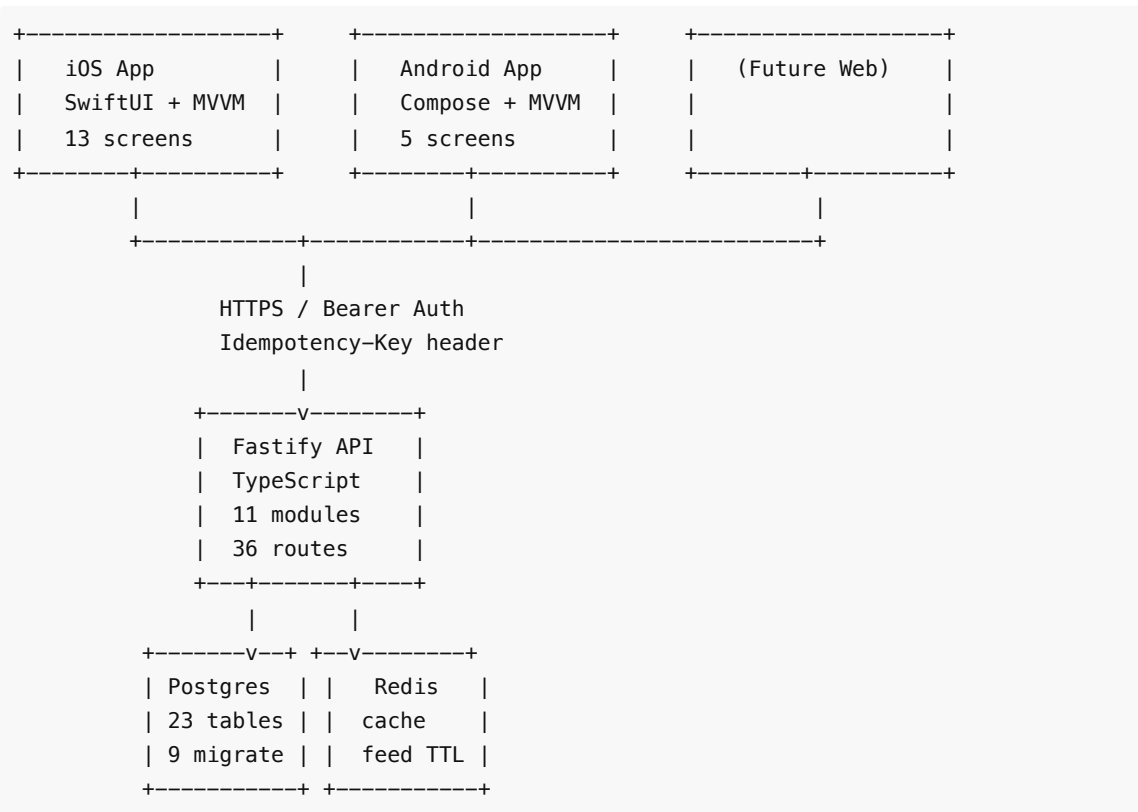
Executive Summary

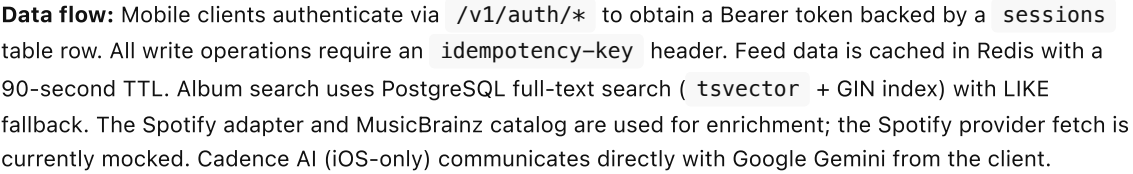
SoundScore is a cross-platform music logging and social discovery application. Users rate albums (0-6 scale), write reviews, curate lists, follow other listeners, and receive weekly recap digests. The system spans three client platforms (iOS, Android, web-ready backend) plus a shared TypeScript contracts package that defines the canonical API types.

The codebase contains **154 source files** totaling **19,220 lines of code** across four targets: a Fastify + TypeScript backend (45 files, 5,531 LOC), a SwiftUI iOS app (67 files, 8,295 LOC), a Kotlin + Jetpack Compose Android app (33 files, 4,874 LOC), and a Zod-based contracts package (9 files, 520 LOC). The deep audit identified **33 issues** (2 P0, 8 P1, 14 P2, 9 P3), of which 3 have been fixed. The backend passes typechecking with zero errors and zero `as any` casts; iOS builds with zero warnings; Android builds successfully. Backend tests show 79 passing / 9 failing (pre-existing, not caused by the audit).

Key strengths: fully parameterized SQL (zero injection risk), structured Pino logging, idempotency-key enforcement on all write routes, Zod-validated environment config, and solid MVVM architecture on both mobile platforms. Key weaknesses: iOS has zero test files, Android test coverage is approximately 15-20%, 8 of 11 backend modules lack tests, and 20 of 36 routes have no contract schema. The Spotify provider integration is still mocked.

System Architecture





backend/src/ config/ env.ts	71 lines	Zod-validated environment config
db/ client.ts	44 lines	Postgres Pool + Redis (ioredis) wrapper
migrate.ts	19 lines	CLI migration runner
runMigrations.ts	44 lines	Programmatic migration runner
lib/ audit.ts	18 files 62 lines	966 lines total Audit event logger with sensitive-field
scrubbing		
dead-letter.ts	72 lines	Dead letter queue for failed async ops
errors.ts	15 lines	ApiError class + factory helpers
idempotency.ts	77 lines	Idempotency-key enforcement middleware
mappers.ts	23 lines	Row-to-DTO mapping utilities
musicbrainz-catalog.ts	134 lines	MusicBrainz search + upsert
normalize.ts	8 lines	Text normalization for canonical matching
notifications.ts	125 lines	Feed cache invalidation + notification queue
pagination.ts	33 lines	Cursor-based pagination helpers
provider-adapter.ts	14 lines	Provider adapter interface
provider-registry.ts	11 lines	Supported provider registry
rate-limit.ts	43 lines	Tiered rate limit hook (auth/sensitive/write)
retry.ts	30 lines	Exponential backoff retry utility
sanitize.ts	12 lines	HTML strip for review body
spotify-adapter.ts	90 lines	Spotify OAuth adapter
spotify-catalog.ts	146 lines	Spotify search + album upsert with metadata
token-refresh.ts	66 lines	DEAD – never imported (ISSUE-002)

util.ts	5 lines	uid() and nowIso() helpers
modules/	11 files	2,809 lines total
tests/	9 files	1,321 lines total
server.ts	209 lines	App factory (middleware, auth, routes, hooks)
index.ts	25 lines	Entry point with graceful shutdown
types.ts	23 lines	Fastify type augmentations

Route Registration (server.ts)

The `buildServer()` function (line 50-209) creates the Fastify instance and wires everything:

- Logger** (line 51-64): Pino with configurable level, custom request serializer, `x-request-id` header propagation, `uid("req")` generation.
- Database** (line 66-72): Creates Postgres pool + Redis via `createDb()`, runs migrations on startup, decorates `app.db`.
- Auth decorator** (line 74-75): `app.requireAuth(request)` resolves Bearer token to `user_id` via `sessions` table lookup with expiry check. Defined at lines 32-48.
- OpenAPI/Swagger** (line 78-96): Auto-generates docs at `/docs`.
- Helmet** (line 98-102): Security headers, CSP disabled (API-only).
- CORS** (line 104-108): Allowlist from `ALLOWED_ORIGINS` env var.
- Global rate limit** (line 110-125): 100 req/min baseline with headers.
- Route-specific rate limits** (line 127): Applied via `applyRouteRateLimits()` hook — auth 10/min, sensitive 3/hr, providers 10/min, writes 30/min.
- Health check** (line 130-145): `/health` with Postgres + Redis connectivity probes, returns 503 if degraded.
- Module registration** (line 147-157): All 11 domain modules registered.
- Request timing hooks** (line 159-181): `onRequest` + `onResponse` for latency logging.
- Graceful shutdown** (line 183-185): `onClose` hook closes DB pool + Redis.
- Error handler** (line 187-206): Catches `ApiError` for structured 4xx responses, falls back to 500 with `requestId`.

Domain Modules (11)

Module	File	Routes	Lines	Description
auth	modules/auth.ts	4	227	Signup, login, refresh, profile (/v1/me)
catalog	modules/catalog.ts	3	233	Search (FTS), album detail, Spotify import
opinions	modules/opinions.ts	4	347	Ratings, reviews (CRUD), recently-played
social	modules/social.ts	5	221	Follow/unfollow, feed (cached), react, comment
lists	modules/lists.ts	3	236	Create list, add items, get list detail
trust	modules/trust.ts	2	224	Account export (GDPR), account deletion
push	modules/push.ts	6	217	Device tokens, notification prefs, test recap
recaps	modules/recaps.ts	2	146	Weekly recap generate + latest
providers	modules/providers.ts	4	243	OAuth connect, callback, status, disconnect

mapping	modules/mapping.ts	2	424	Canonical ID resolution, provider mapping lookup
import	modules/import.ts	3	291	Sync start, status, cancel (provider fetch mocked)

Shared Libraries (18)

Library	File	Lines	Description
audit	lib/audit.ts	62	Security audit trail with sensitive-field scrubbing
dead-letter	lib/dead-letter.ts	72	DLQ for failed async operations
errors	lib/errors.ts	15	ApiError class, badRequest, unauthorized, notFound, conflict
idempotency	lib/idempotency.ts	77	withIdempotency() wrapper using idempotency_keys table
mappers	lib/mappers.ts	23	mapUserProfile(), tryJsonParse() (dead — ISSUE-002)
musicbrainz-catalog	lib/musicbrainz-catalog.ts	134	MusicBrainz XML API search + album upsert
normalize	lib/normalize.ts	8	normalizeText() for canonical matching
notifications	lib/notifications.ts	125	Feed cache invalidation, follower notification queuing
pagination	lib/pagination.ts	33	parsePaginationParams(), buildPaginatedResponse()
provider-adapter	lib/provider-adapter.ts	14	ProviderAdapter interface definition
provider-registry	lib/provider-registry.ts	11	SUPPORTED_PROVIDERS set + getAdapter()
rate-limit	lib/rate-limit.ts	43	applyRouteRateLimits() onRoute hook
retry	lib/retry.ts	30	Exponential backoff with configurable attempts
sanitize	lib/sanitize.ts	12	stripHtml() for review body XSS prevention
spotify-adapter	lib/spotify-adapter.ts	90	Spotify OAuth token exchange + refresh
spotify-catalog	lib/spotify-catalog.ts	146	Spotify search API + upsertAlbumFromSpotify()
token-refresh	lib/token-refresh.ts	66	DEAD CODE — never imported (ISSUE-002)
util	lib/util.ts	5	uid(prefix) nanoid generator, nowIso()

iOS Architecture

Overview

SwiftUI + MVVM + Combine. Single-app target (SoundScore.app). Screens use @StateObject ViewModels that expose @Published properties. All async network calls go through APIClient -> SoundScoreAPI -> SoundScoreRepository . Offline writes are queued via OutboxStore . Theme system uses ThemeManager singleton with SSColors and SSTypography . Cadence AI agent uses direct Gemini API calls from AIBuddyService .

Directory Structure

ios/SoundScore/SoundScore/		
SoundScoreApp.swift	24 lines	App entry point
ContentView.swift	77 lines	Tab navigation root
Config/		
AppConfig.swift	9 lines	Base URL, API version
Secrets.swift	8 lines	API keys (Gemini)
Models/	9 files	438 lines total
Album.swift	32 lines	
FeedItem.swift	14 lines	
NotificationPreferences.swift	10 lines	
PresentationHelpers.swift	284 lines	
SeedData.swift	346 lines	
Track.swift	21 lines	
UserList.swift	10 lines	
UserProfile.swift	16 lines	
WeeklyRecap.swift	11 lines	
Screens/	10 files	2,924 lines total
ViewModels/	7 files	682 lines total
Services/	7 files	1,714 lines total
Components/	27 files	1,910 lines total
Theme/	3 files	223 lines total
SSColors.swift	77 lines	
SSTypography.swift	20 lines	
ThemeManager.swift	126 lines	

Screens (13, including ContentView and SplashScreen)

Screen	File	ViewModel	Lines	Key Feature
AlBuddy	Screens/AlBuddyScreen.swift	AlBuddyViewModel	297	Gemini chat, CadenceCharac action cards
AlbumDetail	Screens/AlbumDetailScreen.swift	AlbumDetailViewModel	454	Track list, per-track ratings, rating sheet
Auth	Screens/AuthScreen.swift	None (ISSUE-009)	180	Login/signup wi inline @State lo

Feed	Screens/FeedScreen.swift	FeedViewModel	314	Activity timeline ErrorBanner, .refreshable
Lists	Screens/ListsScreen.swift	ListsViewModel	94	List cards, ErrorBanner, .refreshable — ORPHANED (ISSUE-008)
Log	Screens/LogScreen.swift	LogViewModel	321	Rating log, albu artwork grid, st ratings
Profile	Screens/ProfileScreen.swift	ProfileViewModel	463	Stats, recent ratings, recap, follow counts
Search	Screens/SearchScreen.swift	SearchViewModel	237	Debounced search, album results grid
Settings	Screens/SettingsScreen.swift	None	378	Theme selectio notifications, export, delete
Splash	Screens/SplashScreen.swift	None	186	Animated launc with CadenceCharac
ContentView	ContentView.swift	None	77	Tab bar root (fe log, search, aiBuddy, profile

Services (8, including app entry)

Service	File	Lines	Description
APIClient	Services/APIClient.swift	258	HTTP layer: GET/POST/PUT/DELETE, Bearer auth, JSON decode
AuthManager	Services/AuthManager.swift	137	Token storage (Keychain), login/signup/refresh, dev auto-auth
SoundScoreAPI	Services/SoundScoreAPI.swift	298	API endpoint methods (22 routes), DTO definitions
SoundScoreRepository	Services/SoundScoreRepository.swift	404	Central data layer, combines API + seed data, auto-auth

AlBuddyService	Services/AlBuddyService.swift	248	Gemini API integration for Cadence AI
OutboxStore	Services/OutboxStore.swift	92	Offline write queue with UserDefaults persistence
SpotifyService	Services/SpotifyService.swift	277	Spotify OAuth + playback SDK integration
SoundScoreApp	SoundScoreApp.swift	24	SwiftUI App entry, environment injection

Component Library (27)

Component	File	Lines	Category
ActionChip	Components/ActionChip.swift	31	Interaction
AlbumArtwork	Components/AlbumArtwork.swift	66	Media
AlbumRatingSheet	Components/AlbumRatingSheet.swift	106	Sheet
AppBackdrop	Components/AppBackdrop.swift	43	Layout
AvatarCircle	Components/AvatarCircle.swift	20	Media
CadenceActionCards	Components/CadenceActionCards.swift	478	AI (largest file)
CadenceCharacter	Components/CadenceCharacter.swift	144	AI
EmptyState	Components/EmptyState.swift	39	Feedback
FloatingTabBar	Components/FloatingTabBar.swift	44	Navigation
GlassCard	Components/GlassCard.swift	101	Layout
GlassIconButton	Components/GlassIconButton.swift	30	DEAD (ISSUE-014)
GlassSegmentedControl	Components/GlassSegmentedControl.swift	37	Interaction
ListCards	Components/ListCards.swift	102	Media
MosaicCover	Components/MosaicCover.swift	30	Media
PillSearchBar	Components/PillSearchBar.swift	41	Input
ReviewSheet	Components/ReviewSheet.swift	103	DEAD (ISSUE-014)
ScreenHeader	Components/ScreenHeader.swift	34	Layout
SectionHeader	Components/SectionHeader.swift	26	Layout
SkeletonView	Components/SkeletonView.swift	36	Loading
SongRatingSheet	Components/SongRatingSheet.swift	98	Sheet
SSButton	Components/SSButton.swift	43	Interaction

StarRating	Components/StarRating.swift	60	Interaction
StatPill	Components/StatPill.swift	30	Data Display
SyncBanner	Components/SyncBanner.swift	26	Feedback
Tab	Components/Tab.swift	39	Navigation
TimelineEntry	Components/TimelineEntry.swift	33	Data Display
TrendChartRow	Components/TrendChartRow.swift	70	Data Display

Android Architecture

Overview

Kotlin + Jetpack Compose + MVVM + Repository pattern. Single-activity app (`MainActivity`) with Compose navigation. ViewModels expose `StateFlow` collected via `collectAsStateWithLifecycle()` . Repository pattern wraps API client + offline outbox. Custom Material 3 theme with glassmorphism design system.

Directory Structure

```

app/src/main/java/com/soundscore/app/
  MainActivity.kt          31 lines
  SoundScoreApp.kt        239 lines  App-level composable, nav host
  data/
    api/
      ApiClient.kt         40 lines  OkHttp HTTP wrapper
      ApiModels.kt         158 lines  DTO definitions
      SoundScoreApi.kt      141 lines  18 endpoint methods
    model/
      DummyData.kt         252 lines  Seed/placeholder data
    repository/
      SoundScoreRepository.kt 470 lines  Central data layer
    sync/
      InMemoryOutboxStore.kt  45 lines  Offline queue (in-memory)
      OutboxOperation.kt      24 lines  Operation type definitions
      OutboxSyncEngine.kt     32 lines  Outbox flush worker
  ui/
    components/
      AlbumArtPlaceholder.kt 103 lines
      AppBackdrop.kt         41 lines
      GlassCard.kt           104 lines
      NewComponents.kt        320 lines  Mixed utility components
      PremiumComponents.kt    301 lines  Premium UI elements
      SoundScoreButton.kt     72 lines
      StarRating.kt           80 lines
    navigation/
      AppNavigation.kt        49 lines  NavHost + route definitions
      DeepLinkResolver.kt     18 lines  Deep link URI parsing
    screens/

```


FeedScreen.kt	334 lines	
ListsScreen.kt	266 lines	
LogScreen.kt	352 lines	
ProfileScreen.kt	435 lines	(second-largest file)
SearchScreen.kt	319 lines	
theme/		
Color.kt	79 lines	
Theme.kt	62 lines	
Type.kt	108 lines	
viewModel/		
FeedViewModel.kt	50 lines	
ListsViewModel.kt	43 lines	
LogViewModel.kt	47 lines	
ProfileViewModel.kt	86 lines	
ScreenPresentation.kt	118 lines	Shared presentation logic
SearchViewModel.kt	55 lines	

Screens (5)

Screen	File	ViewModel	Lines	Key Features
Feed	screens/FeedScreen.kt	FeedViewModel	334	Activity timeline, FeedActivityCard (101 lines)
Lists	screens/ListsScreen.kt	ListsViewModel	266	List cards, album items
Log	screens/LogScreen.kt	LogViewModel	352	Rating grid, album artwork
Profile	screens/ProfileScreen.kt	ProfileViewModel	435	Stats, weekly recap, recent ratings
Search	screens/SearchScreen.kt	SearchViewModel	319	Search bar, results grid

Missing vs iOS (ISSUE-017): AlbumDetailScreen, AuthScreen, AlBuddyScreen, SettingsScreen, SplashScreen.

Shared Contracts

Package: @soundscore/contracts at packages/contracts/ **Runtime:** Zod schemas compiled to TypeScript types **Total:** 9 source files, 520 lines, 27 exported type aliases

File	Lines	Schemas/Types
common.ts	21	CursorPageSchema, ErrorEnvelopeSchema, IdempotencyKeyHeaderSchema
models.ts	122	AlbumSchema, RatingSchema, TrackSchema, TrackRatingSchema, ReviewSchema, UserProfileSchema, ListSchema, WeeklyRecapSchema, NotificationPreferenceSchema, DeviceTokenSchema
endpoints.ts	80	SignUpRequest, LoginRequest, RefreshRequest, AuthResponse, CreateRatingRequest, CreateTrackRatingRequest (dead), CreateReviewRequest, UpdateReviewRequest, CreateListRequest,

		AddListItemRequest, ReactActivityRequest, CommentActivityRequest, UpsertNotificationPreference, RegisterDeviceTokenRequest
events.ts	34	ActivityTypeSchema, ActivityEventSchema, ListeningEventSchema
provider.ts	59	ProviderName, ProviderErrorCode, ConnectProviderRequest, OAuthCallbackRequest, ProviderConnection, ProviderStatusResponse, DisconnectProviderRequest
mapping.ts	81	CanonicalEntityType, CanonicalArtistSchema, CanonicalAlbumSchema, MappingStatus, MappingProvenance, ProviderMappingSchema, MappingLookupRequest, MappingLookupResponse, ResolveMappingRequest
sync.ts	68	SyncType, SyncStatus, SyncTriggerRequest, SyncJobSchema, SyncStatusResponse, SyncCursorSchema, SyncListeningEventSchema, CancelSyncRequest
compliance.ts	47	AttributionPlacement, AttributionRequirement, ComplianceViolation, ComplianceCheckResponse, DataRetentionPolicy
index.ts	8	Re-exports all modules

Coverage gap (ISSUE-030): Only 16 of 36 backend routes are backed by contract schemas. All Phase 2 routes (providers, mapping, sync) use type assertions (`request.body as { ... }`) instead of `schema.parse()` .

Database Schema

Engine: PostgreSQL (via Supabase) **Migrations:** 9 sequential SQL files at `supabase/migrations/` **Total tables:** 23 (including junction and system tables)

Migration 001 — Core Schema

Table	Columns	Key Constraints
schema_migrations	version PK, applied_at	System bookkeeping
users	id PK, email UNIQUE, password_hash, handle, bio, log_count, review_count, list_count, avg_rating, refresh_token, created_at, updated_at	Core user record
sessions	access_token PK, user_id FK->users, created_at, expires_at	Bearer token auth
albums	id PK, title, artist, year, artwork_url, avg_rating, log_count, spotify_id UNIQUE, genres[], popularity, label, total_tracks, search_vector tsvector, created_at, updated_at	Album catalog (enriched in migrations 007-009)

ratings	id PK, user_id FK, album_id FK, value, created_at, updated_at	UNIQUE(user_id, album_id)
reviews	id PK, user_id FK, album_id FK, body, revision, created_at, updated_at	Optimistic concurrency via revision
follows	follower_id FK, followee_id FK	Composite PK
listening_events	id PK, user_id FK, album_id FK, played_at, source, source_ref JSONB, dedup_key	Import deduplication
activity_events	id PK, actor_id FK, type, object_type, object_id, created_at, payload JSONB, reactions, comments	Social feed
lists	id PK, owner_id FK, title, note, created_at, updated_at	User-created lists
list_items	id PK, list_id FK, album_id FK, position, note, created_at	UNIQUE(list_id, position)
idempotency_keys	id SERIAL PK, user_id, route_key, idempotency_key, status, response_json, created_at, updated_at	UNIQUE(user_id, route_key, idempotency_key)
recap_snapshots	id PK, user_id FK, week_start, week_end, payload JSONB, created_at	UNIQUE(user_id, week_start, week_end)
notification_preferences	user_id PK FK, social/recap/comment/reaction_enabled, quiet_hours_start/end, updated_at	One row per user
device_tokens	id PK, user_id FK, platform, device_token UNIQUE, created_at, last_seen_at	Push notification targets
notification_events	id PK, user_id FK, event_type, payload JSONB, is_sent, collapse_key, dedupe_key, created_at	Notification outbox
analytics_events	id PK, user_id (nullable), event_type, payload JSONB, created_at	No FK intentionally

Migration 003 — Audit + Dead Letter

Table	Columns	Notes
audit_events	id PK, user_id (no FK), event_type, details JSONB, ip_address, user_agent, created_at	Retained after account deletion for compliance
dead_letter_events	id PK, original_id, event_type, payload JSONB, error, attempt_count, created_at	Failed async operations

Migration 004 — Canonical Mapping + Sync

Table	Columns	Notes
canonical_artists	id PK, name, normalized_name, created_at	Provider-independent artist IDs
canonical_albums	id PK, title, normalized_title, artist_id FK, year, track_count, artwork_url, created_at	Provider-independent album IDs
provider_mappings	id PK, canonical_id, canonical_type CHECK, provider, provider_id, confidence CHECK(0-1), provenance CHECK, status CHECK, created_at, updated_at	UNIQUE(provider, provider_id)
sync_cursors	user_id FK + provider composite PK, cursor_value, last_sync_at	Resume points
sync_jobs	id PK, user_id FK, provider, sync_type CHECK, status CHECK, progress CHECK(0-100), items_processed, items_total, error, started_at, completed_at, created_at	Async job tracking

Migration 005 — Tracks

Table	Columns	Notes
tracks	id PK, album_id FK CASCADE, title, track_number, duration_ms, spotify_id, created_at	UNIQUE(album_id, track_number)
track_ratings	id PK, user_id FK CASCADE, track_id FK CASCADE, album_id FK CASCADE, value CHECK(0-6), created_at, updated_at	UNIQUE(user_id, track_id)

Migration 006 — Provider OAuth

Table	Columns	Notes
provider_connections	id PK, user_id FK, provider CHECK, access_token, refresh_token, token_expires_at, scopes[], provider_user_id, connected_at, disconnected_at	UNIQUE(user_id, provider)
oauth_states	state PK, user_id FK, provider, redirect_uri, created_at, expires_at (10 min)	CSRF protection

Migration 008 — Spotify Enrichment

Table	Columns	Notes
album_genres	album_id FK + genre composite PK	Genre junction table

Indexes (Notable)

- `idx_albums_search` — GIN index on `search_vector` for full-text search
- `idx_sessions_expires` — For expired session cleanup

- `idx_listening_events_dedup` — Unique partial index on `dedup_key` WHERE NOT NULL
- `idx_mapping_lookup` — `(provider, provider_id)` for fast mapping resolution
- `trg_albums_search_vector` — Trigger auto-updates `search_vector` on title/artist change

API Surface

Base path: `/v1/` **Auth:** Bearer token in `Authorization` header **Idempotency:** Required `idempotency-key` header on all POST/PUT/DELETE **Total routes:** 36 + 1 health check

#	Method	Path	Module	Auth	Idempotency	
1	POST	<code>/v1/auth/signup</code>	auth	No	No	SignUp
2	POST	<code>/v1/auth/login</code>	auth	No	No	LoginF
3	POST	<code>/v1/auth/refresh</code>	auth	No	No	Refres
4	GET	<code>/v1/me</code>	auth	Yes	No	--
5	GET	<code>/v1/search</code>	catalog	No	No	--
6	POST	<code>/v1/albums/from-spotify</code>	catalog	Yes	No	-- (typ
7	GET	<code>/v1/albums/:id</code>	catalog	No	No	--
8	GET	<code>/v1/log/recently-played</code>	opinions	Yes	No	--
9	POST	<code>/v1/ratings</code>	opinions	Yes	Yes	Create
10	POST	<code>/v1/reviews</code>	opinions	Yes	Yes	Create
11	PUT	<code>/v1/reviews/:id</code>	opinions	Yes	Yes	Updat
12	POST	<code>/v1/follow/:userId</code>	social	Yes	Yes	--
13	DELETE	<code>/v1/follow/:userId</code>	social	Yes	Yes	--

14	GET	/v1/feed	social	Yes	No	--
15	POST	/v1/activity/:id/react	social	Yes	Yes	React/
16	POST	/v1/activity/:id/comment	social	Yes	Yes	Comm
17	POST	/v1/lists	lists	Yes	Yes	Create
18	POST	/v1/lists/:id/items	lists	Yes	Yes	AddLis
19	GET	/v1/lists/:id	lists	Yes	No	--
20	POST	/v1/account/export	trust	Yes	No	--
21	DELETE	/v1/account	trust	Yes	No	--
22	POST	/v1/push/tokens	push	Yes	Yes	Registr
23	DELETE	/v1/push/tokens/:deviceToken	push	Yes	No	--
24	GET	/v1/push/preferences	push	Yes	No	--
25	PUT	/v1/push/preferences	push	Yes	No	Upsert
26	GET	/v1/notifications	push	Yes	No	--
27	POST	/v1/notifications/test-recap	push	Yes	Yes	--
28	GET	/v1/recaps/weekly/latest	recaps	Yes	No	--
29	POST	/v1/recaps/weekly/generate	recaps	Yes	Yes	--

30	POST	/v1/providers/:provider/connect	providers	Yes	No	-- (typ
31	POST	/v1/providers/:provider/callback	providers	Yes	No	-- (typ
32	GET	/v1/providers/:provider/status	providers	Yes	No	--
33	POST	/v1/providers/:provider/disconnect	providers	Yes	No	-- (typ
34	GET	/v1/mappings/lookup	mapping	No	No	-- (typ
35	POST	/v1/mappings/resolve	mapping	Yes	No	-- (typ
36	POST	/v1/sync/start	import	Yes	No	-- (typ
37	GET	/v1/sync/status/:sync_id	import	Yes	No	--
38	POST	/v1/sync/cancel	import	Yes	No	-- (typ
--	GET	/health	server	No	No	--

Client coverage:

- iOS: 22 of 36 routes (61%)
- Android: 18 of 36 routes (50%)
- Phase 2 routes (30-38): zero mobile coverage

Code Quality Assessment

Metrics

Metric	Android	iOS	Backend	Contracts
Source files	33	67	45	9
Lines of code	4,874	8,295	5,531	520
Test files	4 (+1 UI)	0	9	0
Test functions	14	0	96	0
Files > 400 lines	2	3	1	0

as any casts	N/A	N/A	0	0
Force-unwraps	N/A	4	N/A	N/A
Typecheck	Pass	Pass (0 warnings)	Pass (0 errors)	Pass
TODOs/FIXMEs	0	0	0	0
Console.log bypass	N/A	N/A	9 (pre-Fastify, acceptable)	N/A
Hardcoded URLs	--	--	47 total across codebase	--

Issues by Severity

Priority	Count	Examples
P0 (Critical)	2	ISSUE-007 (FIXED): iOS stuck offline; ISSUE-007 only P0
P1 (High)	8	Missing Zod validation (001), zero test coverage per module (003), orphaned screen (008), missing Android screens (017), broken smoke tests (019), missing API routes in clients (018, 029, 032)
P2 (Medium)	14	No account lockout (005), force-unwraps (010), missing ErrorBanner (011), missing .refreshable (012), DTO field mismatches (023-027), export HTTP method (028 FIXED), missing contract schemas (030), mocked provider (033)
P3 (Low)	9	Dead exports (002), dead contract schema (006), @ObservedObject misuse (013), dead components (014), hardcoded colors (015), no strings.xml (016), outdated codebase map (031)

Security Review

Authentication

- **Token type:** Bearer tokens stored in `sessions` table with `expires_at` column
- **Password hashing:** bcryptjs with configurable salt rounds (default 10)
- **Session resolution:** `server.ts:32-48` — queries `sessions` WHERE `access_token = $1` AND `expires_at > NOW()`
- **Gap:** No account lockout after failed login attempts (ISSUE-005). Rate limit of 10 req/min per IP is the only defense against brute force.

Rate Limiting

Category	Limit	Routes
Global baseline	100 req/min	All <code>/v1/*</code> routes
Auth routes	10 req/min	<code>/v1/auth/signup</code> , <code>/v1/auth/login</code> , <code>/v1/auth/refresh</code>
Sensitive routes	3 req/hour	<code>/v1/account/export</code> , <code>/v1/account</code>
Provider routes	10 req/min	<code>/v1/providers/*</code>

Write operations	30 req/min	All POST/PUT/DELETE not in above categories
------------------	------------	---

SQL Injection Protection

All database queries use parameterized placeholders (`$1` , `$2` , etc.) through the `pg.Pool.query()` method. Zero instances of template-literal SQL interpolation found in the codebase.

XSS Prevention

- Review body sanitized via `stripHtml()` in `lib/sanitize.ts`
- Helmet security headers enabled (CSP disabled for API-only server)

Secret Management

- Environment variables validated through Zod schema (`config/env.ts`)
- Production requires explicit `DATABASE_URL` and `REDIS_URL` (no fallback to dev defaults)
- Spotify credentials warn if missing but do not crash
- iOS stores Gemini API key in `Secrets.swift` (committed to repo — should be moved to xcconfig or Keychain)

Audit Trail

- `lib/audit.ts` logs security events to `audit_events` table
- Sensitive fields (`password` , `token` , `email` , etc.) automatically scrubbed from audit details
- Audit events retained after account deletion (no FK to users) for compliance

Idempotency

- All write routes require `idempotency-key` header (`lib/idempotency.ts`)
- Keys tracked in `idempotency_keys` table with `UNIQUE(user_id, route_key, idempotency_key)`
- Completed responses cached as JSONB for replay

Test Coverage

Backend (9 test files, 96 functions)

Test File	Functions	Lines	Status
<code>integration.test.ts</code>	~25	337	1 failure (idempotency 409 vs expected 200)
<code>error-handling.test.ts</code>	~12	222	1 failure (malformed JSON returns 500 not 400)
<code>production-readiness.test.ts</code>	~10	169	Multiple failures (stale structural checks)
<code>providers.test.ts</code>	~15	172	Pass
<code>audit.test.ts</code>	~8	110	Pass
<code>mapping.test.ts</code>	~8	109	Pass
<code>import.test.ts</code>	~6	90	Pass

retry.test.ts	~8	90	Pass
mappers.test.ts	~4	22	Pass

Result: 79 pass, 9 fail (88 total). All failures are pre-existing. **Modules with zero tests:** auth, catalog, opinions, social, lists, trust, push, recaps (8 of 11). **No integration tests** for any route handler.

iOS (0 test files)

No test files exist. Zero coverage. This is the single largest quality gap in the project.

Android (5 test files, 14 functions)

Test File	Functions	Lines	Status
ScreenPresentationTest.kt	5	52	Pass
OutboxSyncEngineTest.kt	3	54	Pass
SoundScoreRepositoryMappingTest.kt	2	26	Pass
DeepLinkResolverTest.kt	2	18	Pass
ScreenSmokeTest.kt (UI)	5	136	BROKEN — stale assertions (ISSUE-019)

Estimated coverage: 15-20%. No ViewModel tests, no Repository tests, no API layer tests.

Known Issues and Technical Debt

P0 — Critical (2 issues, 1 fixed)

ID	Title	Platform	Status
ISSUE-007	iOS stuck in offline/seed-data mode	iOS	FIXED

P1 — High (8 issues)

ID	Title	Platform	Status
ISSUE-001	Missing Zod validation in 10+ route handlers	Backend	Documented
ISSUE-003	8/11 backend modules have zero test files	Backend	Documented
ISSUE-008	ListsScreen orphaned (not in tab bar)	iOS	Documented
ISSUE-016	No strings.xml — all Android strings hardcoded	Android	Documented
ISSUE-017	5 iOS screens missing from Android	Android	Documented
ISSUE-018	12 backend routes missing from Android API client	Android	Documented
ISSUE-019	Android smoke tests broken (stale assertions)	Android	Documented
ISSUE-020	Android test coverage ~15-20% (target 80%)	Android	Documented

ISSUE-029	iOS has 3 track routes with no backend implementation	iOS	Documented
ISSUE-032	Phase 2 has zero mobile client coverage	Cross	Documented

P2 — Medium (14 issues, 1 fixed)

ID	Title	Platform	Status
ISSUE-005	No account lockout after failed logins	Backend	Documented
ISSUE-009	AuthScreen has no ViewModel	iOS	Documented
ISSUE-010	4 force-unwraps in iOS code	iOS	Documented
ISSUE-011	3 screens missing ErrorBanner	iOS	Documented
ISSUE-012	3 scrollable screens missing .refreshable	iOS	Documented
ISSUE-021	Large composables needing decomposition	Android	Documented
ISSUE-022	Android missing Track/TrackRating DTOs	Android	Documented
ISSUE-023	iOS WeeklyRecapDto missing fields vs backend	Cross	Documented
ISSUE-024	iOS ActivityEventDto missing payload field	Cross	Documented
ISSUE-025	iOS Album model has orphan fields	iOS	Documented
ISSUE-026	UserProfile UI models missing id field	Cross	Documented
ISSUE-027	UserProfile has fields backend does not return	Cross	Documented
ISSUE-028	iOS export uses GET, backend requires POST	iOS	FIXED
ISSUE-030	20/36 backend routes lack contract schemas	Backend	Documented
ISSUE-033	Provider fetch still mocked in import.ts	Backend	Documented

P3 — Low (9 issues)

ID	Title	Platform	Status
ISSUE-002	Dead exports in backend lib (6 symbols)	Backend	Documented
ISSUE-004	Console.log in migration/config code	Backend	Documented (acceptable)
ISSUE-006	CreateTrackRatingRequestSchema dead in contracts	Contracts	Documented
ISSUE-013	@ObservedObject misuse on ThemeManager.shared	iOS	Documented
ISSUE-014	2 unused component files (GlassIconButton, ReviewSheet)	iOS	Documented

ISSUE-015	Hardcoded colors in 3 screens	iOS	Documented
ISSUE-031	CONTEXT_04_CODEBASE_MAP.md significantly outdated	Docs	Documented

Recommendations

Ordered by impact (highest first):

1. Add iOS test coverage (P1, high impact)

Zero test files is the largest quality gap. Start with:

- Unit tests for all 7 ViewModels (most critical: FeedViewModel, ProfileViewModel)
- Integration tests for APIClient and SoundScoreRepository
- Snapshot tests for key components (CadenceActionCards, AlbumRatingSheet)

2. Wire Zod validation into Phase 2 handlers (P1)

Replace all `request.body as {...}` type assertions with contract schema `.parse()` calls. This converts 500 errors on malformed input into 400 validation errors. Affects: `catalog.ts`, `import.ts`, `mapping.ts`, `providers.ts` (10+ handlers).

3. Fix Android test suite (P1)

- Fix 5 broken smoke test assertions to match current screen text
- Add ViewModel unit tests for all 5 ViewModels
- Add Repository tests with mocked API
- Target: bring coverage from 15% to 50%+ in one sprint

4. Implement missing Android screens (P1)

Priority order: AuthScreen (required for real users), AlbumDetailScreen (core feature), SettingsScreen, AlBuddyScreen, SplashScreen.

5. Add account logout (P2)

Implement progressive logout after N failed login attempts (e.g., 5 failures = 15-minute logout). Current 10 req/min rate limit allows 14,400 password attempts per day.

6. Connect real Spotify provider fetch (P2)

Replace mock `fetchRecentPlays()` in `import.ts` with actual Spotify Recently Played API calls using the `spotify-adapter.ts` OAuth flow.

7. Add mobile clients for Phase 2 routes (P1)

Neither iOS nor Android can call any provider/mapping/sync routes. Add API client methods for at minimum: provider connect/disconnect, sync start/status.

8. Resolve DTO field mismatches (P2)

- Add `payload` to iOS `ActivityEventDto`
- Add `userId`, `topAlbums`, `createdAt` to iOS `WeeklyRecapDto`

- Remove orphan fields from iOS `Album` model (`spotifyId` , `genres`)
- Add `id` to both platforms' `UserProfile` model

9. Wire ListsScreen into iOS tab bar (P1)

Screen is fully built with ViewModel, ErrorBanner, and .refreshable but unreachable. Add a lists tab to `Tab.swift` or integrate via navigation link.

10. Extract AuthViewModel for iOS (P2)

Move login/signup business logic from inline `@State` in `AuthScreen.swift` to a proper ViewModel for testability.

Appendix: Source File Tree

Backend (45 files, 5,531 lines)

<code>backend/src/config/env.ts</code>	71
<code>backend/src/db/client.ts</code>	44
<code>backend/src/db/migrate.ts</code>	19
<code>backend/src/db/runMigrations.ts</code>	44
<code>backend/src/index.ts</code>	25
<code>backend/src/server.ts</code>	209
<code>backend/src/types.ts</code>	23
<code>backend/src/lib/audit.ts</code>	62
<code>backend/src/lib/dead-letter.ts</code>	72
<code>backend/src/lib/errors.ts</code>	15
<code>backend/src/lib/idempotency.ts</code>	77
<code>backend/src/lib/mappers.ts</code>	23
<code>backend/src/lib/musicbrainz-catalog.ts</code>	134
<code>backend/src/lib/normalize.ts</code>	8
<code>backend/src/lib/notifications.ts</code>	125
<code>backend/src/lib/pagination.ts</code>	33
<code>backend/src/lib/provider-adapter.ts</code>	14
<code>backend/src/lib/provider-registry.ts</code>	11
<code>backend/src/lib/rate-limit.ts</code>	43
<code>backend/src/lib/retry.ts</code>	30
<code>backend/src/lib/sanitize.ts</code>	12
<code>backend/src/lib/spotify-adapter.ts</code>	90
<code>backend/src/lib/spotify-catalog.ts</code>	146
<code>backend/src/lib/token-refresh.ts</code>	66
<code>backend/src/lib/util.ts</code>	5
<code>backend/src/modules/auth.ts</code>	227
<code>backend/src/modules/catalog.ts</code>	233
<code>backend/src/modules/import.ts</code>	291
<code>backend/src/modules/lists.ts</code>	236
<code>backend/src/modules/mapping.ts</code>	424
<code>backend/src/modules/opinions.ts</code>	347
<code>backend/src/modules/providers.ts</code>	243
<code>backend/src/modules/push.ts</code>	217
<code>backend/src/modules/recaps.ts</code>	146
<code>backend/src/modules/social.ts</code>	221

backend/src/modules/trust.ts	224
backend/src/tests/audit.test.ts	110
backend/src/tests/error-handling.test.ts	222
backend/src/tests/import.test.ts	90
backend/src/tests/integration.test.ts	337
backend/src/tests/mappers.test.ts	22
backend/src/tests/mapping.test.ts	109
backend/src/tests/production-readiness.test.ts	169
backend/src/tests/providers.test.ts	172
backend/src/tests/retry.test.ts	90

iOS (67 files, 8,295 lines)

ios/.../SoundScoreApp.swift	24
ios/.../ContentView.swift	77
ios/.../Config/AppConfig.swift	9
ios/.../Config/Secrets.swift	8
ios/.../Models/Album.swift	32
ios/.../Models/FeedItem.swift	14
ios/.../Models/NotificationPreferences.swift	10
ios/.../Models/PresentationHelpers.swift	284
ios/.../Models/SeedData.swift	346
ios/.../Models/Track.swift	21
ios/.../Models/UserList.swift	10
ios/.../Models/UserProfile.swift	16
ios/.../Models/WeeklyRecap.swift	11
ios/.../Screens/AIBuddyScreen.swift	297
ios/.../Screens/AlbumDetailScreen.swift	454
ios/.../Screens/AuthScreen.swift	180
ios/.../Screens/FeedScreen.swift	314
ios/.../Screens/ListsScreen.swift	94
ios/.../Screens/LogScreen.swift	321
ios/.../Screens/ProfileScreen.swift	463
ios/.../Screens/SearchScreen.swift	237
ios/.../Screens/SettingsScreen.swift	378
ios/.../Screens/SplashScreen.swift	186
ios/.../Services/AIBuddyService.swift	248
ios/.../Services/APIClient.swift	258
ios/.../Services/AuthManager.swift	137
ios/.../Services/OutboxStore.swift	92
ios/.../Services/SoundScoreAPI.swift	298
ios/.../Services/SoundScoreRepository.swift	404
ios/.../Services/SpotifyService.swift	277
ios/.../Theme/SSColors.swift	77
ios/.../Theme/SSTypography.swift	20
ios/.../Theme/ThemeManager.swift	126
ios/.../ViewModels/AIBuddyViewModel.swift	210
ios/.../ViewModels/AlbumDetailViewModel.swift	56
ios/.../ViewModels/FeedViewModel.swift	66
ios/.../ViewModels/ListsViewModel.swift	44
ios/.../ViewModels/LogViewModel.swift	68

ios/.../ViewModels/ProfileViewModel.swift	145
ios/.../ViewModels/SearchViewModel.swift	93
ios/.../Components/ActionChip.swift	31
ios/.../Components/AlbumArtwork.swift	66
ios/.../Components/AlbumRatingSheet.swift	106
ios/.../Components/AppBackdrop.swift	43
ios/.../Components/AvatarCircle.swift	20
ios/.../Components/CadenceActionCards.swift	478
ios/.../Components/CadenceCharacter.swift	144
ios/.../Components/EmptyState.swift	39
ios/.../Components/FloatingTabBar.swift	44
ios/.../Components/GlassCard.swift	101
ios/.../Components/GlassIconButton.swift	30
ios/.../Components/GlassSegmentedControl.swift	37
ios/.../Components/ListCards.swift	102
ios/.../Components/MosaicCover.swift	30
ios/.../Components/PillSearchBar.swift	41
ios/.../Components/ReviewSheet.swift	103
ios/.../Components/ScreenHeader.swift	34
ios/.../Components/SectionHeader.swift	26
ios/.../Components/SkeletonView.swift	36
ios/.../Components/SongRatingSheet.swift	98
ios/.../Components/SSButton.swift	43
ios/.../Components/StarRating.swift	60
ios/.../Components/StatPill.swift	30
ios/.../Components/SyncBanner.swift	26
ios/.../Components/Tab.swift	39
ios/.../Components/TimelineEntry.swift	33
ios/.../Components/TrendChartRow.swift	70

Android (33 source + 5 test files, 4,874 + 286 test lines)

app/.../MainActivity.kt	31
app/.../SoundScoreApp.kt	239
app/.../data/api/ApiClient.kt	40
app/.../data/api/ApiModels.kt	158
app/.../data/api/SoundScoreApi.kt	141
app/.../data/model/DummyData.kt	252
app/.../data/repository/SoundScoreRepository.kt	470
app/.../data/sync/InMemoryOutboxStore.kt	45
app/.../data/sync/OutboxOperation.kt	24
app/.../data/sync/OutboxSyncEngine.kt	32
app/.../ui/components/AlbumArtPlaceholder.kt	103
app/.../ui/components/AppBackdrop.kt	41
app/.../ui/components/GlassCard.kt	104
app/.../ui/components/NewComponents.kt	320
app/.../ui/components/PremiumComponents.kt	301
app/.../ui/components/SoundScoreButton.kt	72
app/.../ui/components/StarRating.kt	80
app/.../ui/navigation/AppNavigation.kt	49
app/.../ui/navigation/DeepLinkResolver.kt	18

app/.../ui/screens/FeedScreen.kt	334
app/.../ui/screens/ListsScreen.kt	266
app/.../ui/screens/LogScreen.kt	352
app/.../ui/screens/ProfileScreen.kt	435
app/.../ui/screens/SearchScreen.kt	319
app/.../ui/theme/Color.kt	79
app/.../ui/theme/Theme.kt	62
app/.../ui/theme/Type.kt	108
app/.../ui/viewmodel/FeedViewModel.kt	50
app/.../ui/viewmodel/ListsViewModel.kt	43
app/.../ui/viewmodel/LogViewModel.kt	47
app/.../ui/viewmodel/ProfileViewModel.kt	86
app/.../ui/viewmodel/ScreenPresentation.kt	118
app/.../ui/viewmodel/SearchViewModel.kt	55
--- tests ---	
app/.../test/.../ScreenPresentationTest.kt	52
app/.../test/.../DeepLinkResolverTest.kt	18
app/.../test/.../SoundScoreRepositoryMappingTest.kt	26
app/.../test/.../OutboxSyncEngineTest.kt	54
app/.../androidTest/.../ScreenSmokeTest.kt	136

Contracts (9 files, 520 lines)

packages/contracts/src/index.ts	8
packages/contracts/src/common.ts	21
packages/contracts/src/models.ts	122
packages/contracts/src/endpoints.ts	80
packages/contracts/src/events.ts	34
packages/contracts/src/provider.ts	59
packages/contracts/src/mapping.ts	81
packages/contracts/src/sync.ts	68
packages/contracts/src/compliance.ts	47

Database Migrations (9 files)

```

supabase/migrations/20240101000001_phase1b_core.sql
supabase/migrations/20240101000002_notification_hardening.sql
supabase/migrations/20240101000003_audit_dead_letter.sql
supabase/migrations/20240101000004_canonical_mapping_sync.sql
supabase/migrations/20240101000005_tracks_and_track_ratings.sql
supabase/migrations/20240101000006_provider_connections.sql
supabase/migrations/20240101000007_session_expiry_and_indexes.sql
supabase/migrations/20240101000008_album_spotify_metadata.sql
supabase/migrations/20240101000009_album_timestamps.sql

```

End of report. Generated as Pass 9 of the SoundScore deep audit.